

Política de Segurança da Informação — Flow Hub

Documento interno de **FLOW SYSTEMS LTDA** (CNPJ 62.479.299/0001-66), que formaliza os princípios, processos e categorias de controles adotados para proteger a plataforma Flow Hub e os dados pessoais nela tratados.

Esta Política é escrita em nível de princípios e processos, e não de mecanismos técnicos específicos — os detalhes de implementação evoluem com a arquitetura da plataforma e são tratados em documentação técnica interna, não neste documento.

Última atualização: 31 de julho de 2026

1. Objetivo e Escopo

Esta Política estabelece os princípios de segurança da informação adotados pela Flow Hub, servindo como referência interna e documento de accountability perante clientes, parceiros e a Autoridade Nacional de Proteção de Dados (ANPD). Aplica-se a toda a infraestrutura, aplicação, colaboradores e processos que tratam dados pessoais de clientes contratantes e de seus contatos finais.

2. Classificação da Informação

As informações tratadas pela Flow Hub são classificadas conforme sua sensibilidade, para orientar o nível de controle de acesso e proteção aplicável:

- **Pública:** informações institucionais e de marketing, sem restrição de acesso.
 - **Uso interno:** informações operacionais da empresa, sem sensibilidade especial, mas não destinadas à divulgação externa.
 - **Confidencial:** dados de clientes contratantes e de seus contatos finais, informações comerciais e contratuais.
 - **Restrita:** credenciais de acesso, chaves de API, segredos de infraestrutura e dados financeiros sensíveis, com acesso limitado a pessoas estritamente autorizadas.
-

3. Gestão de Ativos

A Flow Hub mantém responsáveis definidos pelos principais ativos de informação da plataforma: base de código-fonte, banco de dados e infraestrutura de hospedagem, credenciais e segredos de acesso, e documentação de processos. A responsabilidade por cada ativo inclui zelar por sua integridade, disponibilidade e controle de acesso adequado.

4. Gestão de Riscos

A Flow Hub avalia periodicamente os riscos de segurança e privacidade associados à sua arquitetura e operação, priorizando tratamento conforme impacto potencial e probabilidade. Essa avaliação é revisada sempre que uma mudança relevante é introduzida na plataforma (nova integração, novo fluxo de dados, nova funcionalidade com tratamento

de dados pessoais), e à medida que a empresa cresce, esse processo tende a se formalizar em um registro de riscos estruturado.

5. Controle de Acesso e Gestão de Identidade

O acesso à plataforma é segmentado por conta (multi-tenant), com hierarquia de papéis — proprietário, administrador, agente e visualizador — cada um com permissões progressivamente mais restritas. A autenticação de usuários é realizada por meio de provedor de identidade dedicado. A Flow Hub busca adotar boas práticas de autenticação, incluindo o incentivo ao uso de autenticação multifator quando disponível, e políticas de senha alinhadas a padrões de mercado.

6. Gestão de Acessos Privilegiados

O acesso administrativo de mais alto nível (com visibilidade sobre todas as contas da plataforma) é restrito a um grupo controlado de pessoas, com processo formal de concessão e revogação, travas contra auto-revogação e contra a remoção do último administrador do sistema, e trilha de auditoria completa (quem concedeu/revogou, para quem, quando). A relação de pessoas com esse nível de acesso deve ser revisada periodicamente, para garantir que permaneça restrita ao estritamente necessário.

7. Isolamento de Dados entre Clientes

Todos os dados são isolados logicamente por conta — cada operação é automaticamente restrita aos dados da conta à qual o usuário autenticado pertence, incluindo mecanismos de validação em múltiplas camadas para reduzir o risco de acesso indevido entre contas. Endpoints sensíveis (exportação, anonimização e alteração de consentimento de contatos) possuem verificação de propriedade de conta em mais de uma camada de proteção.

8. Criptografia

Credenciais sensíveis armazenadas pela plataforma — como tokens de integração com serviços de mensageria e chaves de API de provedores de Inteligência Artificial fornecidas pelos clientes (modelo BYOK/BYOA) — são criptografadas em repouso utilizando mecanismos criptográficos adequados ao tipo de dado tratado, seguindo práticas reconhecidas de mercado. Toda comunicação com a plataforma ocorre por meio de conexões criptografadas.

9. Segurança de Arquivos e Mídia

Arquivos de mídia trocados em conversas e demais anexos são armazenados de forma privada, sem acesso público direto. A entrega de mídia a serviços externos ocorre por meio de mecanismos de acesso temporário e controlado, nunca por links permanentes e públicos.

10. Segurança de Aplicação

A plataforma adota mecanismos de limitação de requisições contra abuso e mecanismos de proteção contra ataques comuns ao navegador (como restrição de origens de scripts e conexões de rede autorizadas), revisados periodicamente conforme a evolução de boas práticas de mercado.

As preferências de consentimento de cookies são armazenadas de forma separada dos mecanismos de autenticação da plataforma, e não são utilizadas para criação de perfis de usuários.

11. Segurança do Assistente de Inteligência Artificial

O assistente de IA implementa mecanismos de proteção destinados à identificação de tentativas de manipulação (como injeção de comandos e tentativas de jailbreak) por eles identificadas, podendo bloquear a interação, registrar o evento de segurança e encaminhar o atendimento a um agente humano quando apropriado. O assistente não possui autonomia para executar ações com efeito jurídico ou financeiro sobre os sistemas do cliente.

12. Gestão de Vulnerabilidades

Vulnerabilidades identificadas — por meio de monitoramento próprio, relato de terceiros ou atualização de dependências — são avaliadas quanto ao impacto e criticidade, priorizadas conforme risco, e tratadas dentro de prazos definidos internamente conforme sua severidade.

13. Gestão de Mudanças

Mudanças relevantes na aplicação passam por revisão antes da implantação em produção, incluindo verificação automatizada de qualidade (testes e checagem de tipos) como parte do processo de integração contínua.

14. Ambientes de Desenvolvimento e Produção

O desenvolvimento da plataforma ocorre em ambiente local separado do ambiente de produção. Atualmente, considerando o estágio operacional da plataforma, mudanças aprovadas são implantadas em produção mediante o processo de revisão e validação técnica descrito na Cláusula 13, incluindo verificação automatizada de qualidade. A adoção de um ambiente de homologação intermediário persistente é um item avaliado para evolução futura do processo de desenvolvimento, à medida que a complexidade da plataforma e da equipe justifique essa etapa adicional.

15. Monitoramento e Detecção

A plataforma utiliza captura automatizada de exceções de aplicação e verificação periódica de disponibilidade dos serviços. Eventos de segurança relevantes — incluindo tentativas críticas de manipulação do assistente de IA e alterações em acessos privilegiados — geram alerta em tempo hábil para a equipe operacional responsável.

16. Gestão de Logs

Os registros técnicos e de auditoria mantidos pela plataforma observam controle de acesso restrito, prazo de retenção definido conforme a finalidade de cada registro, e sincronização temporal consistente, de modo a preservar sua utilidade para investigação e auditoria.

17. Continuidade de Negócios e Backup

O banco de dados relacional possui rotina de backup automatizado. Os backups atualmente abrangem o banco de dados relacional; a estratégia de proteção de arquivos armazenados em outras camadas de armazenamento é periodicamente reavaliada conforme a evolução da plataforma e dos requisitos de negócio. A Flow Hub busca manter objetivos razoáveis de tempo e ponto de recuperação, a serem formalizados numericamente à medida que a operação amadurecer.

18. Gestão de Dispositivos e Acesso Remoto

Colaboradores e prestadores com acesso a sistemas de produção devem observar práticas adequadas de segurança em seus dispositivos, incluindo controle de acesso, proteção contra software malicioso e cuidado no manuseio de credenciais, mesmo em ambiente de trabalho remoto. Esse tema é candidato a política dedicada à medida que a equipe cresça.

19. Conscientização e Treinamento

A Flow Hub busca manter seus colaboradores informados sobre práticas de segurança da informação e proteção de dados pessoais relevantes às suas funções, promovendo essa conscientização de forma contínua conforme a equipe se expande.

20. Gestão de Fornecedores e Cadeia de Suprimentos

Fornecedores de infraestrutura, pagamento e demais serviços essenciais à operação da plataforma são selecionados considerando práticas de segurança reconhecidas no mercado. Integrações de mensageria e de Inteligência Artificial seguem o modelo BYOK/BYOA, com credenciais e responsabilidade contratual do próprio cliente perante esses fornecedores. O inventário detalhado de operadores e suboperadores consta do Registro das Operações de Tratamento (RAT).

21. Resposta a Incidentes

A Flow Hub mantém Plano de Resposta a Incidentes de Segurança específico, que detalha o processo de detecção, contenção, avaliação de severidade, notificação à ANPD e aos titulares afetados quando aplicável, remediação e registro de lições aprendidas, em conformidade com o Art. 48 da LGPD.

22. Revisão desta Política

Esta Política deve ser revisada sempre que houver mudança relevante na arquitetura de segurança da plataforma, e ao menos uma vez por ano.

FLOW SYSTEMS LTDA — CNPJ 62.479.299/0001-66